SOFTWARE REQUIREMENTS SPECIFICATION · VERSIÓN 1.0

Agency Orchestrator Salud

Plataforma SaaS con IA para consultorios de salud mental en Ecuador: gestión de pacientes, historia clínica, agenda, tests psicológicos, gestión documental, marketing con consentimiento y gobierno de datos según la LOPDP.

Fecha: 9 de octubre de 2026 · Repositorio: `tatymarisol44-cmyk/Tatos` · Estado: MVP construido, ensayado por CI en cada cambio; uso con pacientes reales pendiente de los pasos legales.

---

0. Control del documento

Campo	Valor
Producto	Agency Orchestrator, vertical de salud mental (psicología y psiquiatría), Ecuador
Tipo	Especificación de requisitos (SRS) + registro de decisiones de producto y arquitectura
Versión	1.0 (español). Sustituye como referencia de negocio a `docs/SRS.md` v0.x (inglés), que sigue siendo la referencia técnica fina por requisito.
Repositorio	GitHub `tatymarisol44-cmyk/Tatos`, rama `main` protegida (ruleset `main-protegida`)
Último commit verificado	`5020f70` (9 oct. 2026)
Código	Python 3.12–3.13 (núcleo), Java 21 / Spring AI (agente remoto A2A), HTML/JS sin build (consola)
Pruebas	900 pasan, 20 omitidas en local (Postgres real y navegador; corren en CI); cobertura 95,2 %; ruff + mypy `--strict` limpios
Marco legal	LOPDP (R.O. 459, 2021) y resoluciones SPDP 2025-0006, 2025-0028, 2026-0004, 2026-0005; ACESS-2022-0046 (receta especial)
Principio rector	Ninguna afirmación del producto sin la cadena **requisito → implementación → prueba → evidencia en CI**. Lo que no tiene esa cadena se marca como parcial o futuro.

> **Regla de lectura.** Cada requisito lleva su estado: `I` implementado y probado, `P` parcial, `F` futuro. La columna "Verificación" nombra el módulo de pruebas en `tests/` que lo demuestra. Las decisiones se marcan como CONFIRMADA, DECIDIDA POR LA IA (bajo autoridad de la dueña) o PENDIENTE.

1. Resumen ejecutivo

Agency Orchestrator Salud es una plataforma para que un consultorio de psicología o psiquiatría lleve a sus pacientes, su historia clínica, su agenda, sus tests y su comunicación en un solo lugar, con inteligencia artificial que ayuda sin reemplazar al profesional. Es multiempresa: cada consultorio es un *tenant* aislado, con varios profesionales, y cada profesional trabaja con el "paquete" de su profesión (qué documentos puede escribir, qué no puede prometer en publicidad, qué puede prescribir).

La IA responde preguntas cotidianas con el conocimiento del propio consultorio, redacta borradores de campañas y contesta WhatsApp con calidez, pero tiene límites duros: no da consejos médicos, no diagnostica, no lee notas de psicoterapia, no contesta mensajes de crisis (esos van a una persona de guardia) y toda respuesta clínica riesgosa queda retenida hasta que un profesional la revisa.

El gobierno de datos está construido según la LOPDP ecuatoriana: consentimientos por finalidad, auditoría encadenada con hashes, derechos de acceso y borrado, registro de casos de privacidad con plazos legales, necesidad de saber para datos clínicos y seudónimos para los datos de marketing.

113 operaciones de API REST (OpenAPI)	**900** pruebas automáticas que pasan	**21** decisiones de arquitectura (ADR)
18 migraciones de esquema (Alembic)	**260** agentes especialistas en el catálogo	**US$0** costo del perfil de producción MVP

```
PACIENTE → CONSENTIMIENTO → CITA → SESIÓN → DOCUMENTO CLÍNICO → TEST → SEGUIMIENTO → RECORD
```

2. Propósito, alcance y no objetivos

2.1 Propósito

Este SRS consolida qué hace el producto, cómo se verifica y qué falta. Está escrito para una auditoría técnica (código limpio, reproducibilidad, escalabilidad y CI/CD) y como base contractual con los consultorios piloto.

2.2 Alcance funcional

- Consultorios (tenants), profesionales con su paquete de profesión, personal con roles, inicio de sesión con MFA.
- Gestión de pacientes: alta, búsqueda, edición, restricción, acceso del paciente a su propia app.
- Perfil del paciente: historia clínica de solo agregar, tests aplicados con puntaje, archivos clínicos, seguimiento, consentimientos.
- Agenda por profesional, horarios, turnos libres, reservas sin choques, calendario para el celular, recordatorios.
- Gestión documental: documentos clínicos tipados por profesión, archivos firmados fuera de la plataforma, base de conocimiento del consultorio, plantillas legales.
- Tests psicológicos propios y plantillas de dominio público (PHQ-9, GAD-7) con alertas por ítem.
- Asistente con IA: respuestas desde el conocimiento del consultorio, revisión humana de respuestas riesgosas, enrutamiento a 260 especialistas.
- Marketing: segmentos, campañas con grupo control y estadística, creatividades generadas por código, publicación en redes con aprobación, WhatsApp entrante.
- Seguridad del paciente: detección de crisis, guardia con escalamiento, líneas oficiales (ECU 911, 171 opción 6).
- Privacidad: auditoría encadenada, exportación y borrado, registro de casos con plazos LOPDP.

2.3 Fuera de alcance (no objetivos)

- La IA no diagnostica, no prescribe y no da consejo terapéutico.
- La plataforma no emite la receta especial oficial de ACESS: solo valida la hoja de trabajo que el médico copia al formulario numerado.
- No se contacta a terceros (familia, policía) automáticamente ante una crisis: solo se alerta al profesional tratante y a la guardia.
- No se usan datos de salud anonimizados entre consultorios sin aprobación previa de la SPDP (LOPDP Art. 31.3).
- No hay facturación electrónica ni inventario en esta versión (ERP: futuro).
- No se promete disponibilidad por encima de un servidor en el perfil MVP (ver ADR 0021).

3. Principios no negociables

ID	Principio	Cómo se cumple
`P-01`	Necesidad de saber	Los datos clínicos solo los lee quien tiene el rol clínico de forma explícita; ni administración ni llaves de servicio (LOPDP Art. 10.e).
`P-02`	La IA asiste, no decide	Respuestas clínicas riesgosas retenidas para revisión humana; campañas y publicaciones requieren aprobación de una persona.
`P-03`	Crisis siempre a una persona	Los mensajes de crisis nunca llegan al modelo; textos fijos revisados y alerta a la guardia con escalamiento a los 5 minutos.
`P-04`	Consentimiento por finalidad	Marketing, analítica y memoria tienen consentimientos separados; sin respuesta = no.
`P-05`	Historia clínica de solo agregar	Nada se edita ni se borra; una corrección es una entrada nueva que "enmienda" la anterior.
`P-06`	Notas de psicoterapia solo para su autor	Ni otros profesionales ni administración; excluidas de búsqueda, memoria, métricas, campañas, modelos y exportación.
`P-07`	Aislamiento entre consultorios	Toda tabla con clave que empieza por el tenant; una matriz de pruebas ataca cada operación de la API desde otro consultorio.
`P-08`	Medir antes de afirmar	Campañas con grupo control; resultados "provisionales" hasta cerrar la ventana; "no concluyente" con menos de 30 por grupo.
`P-09`	Reproducibilidad	Dependencias bloqueadas, imágenes por digest, firmadas, construidas desde el mismo lockfile; cada push se ensaya completo en CI.
`P-10`	Fallar con elegancia	Si falla un componente opcional (modelo, búsqueda, memoria), el sistema degrada a textos fijos o reglas, nunca a silencio.
`P-11`	Sin datos de pacientes en señales técnicas	Logs redactados, alertas sin datos personales, métricas agregadas.
`P-12`	Honestidad legal	Cada referencia legal tiene estado: leída en fuente primaria, secundaria o "por verificar"; un paquete de producción no puede apoyarse en referencias sin verificar.

4. Actores, usuarios y roles

Actor	Rol técnico	Responsabilidad
Dirección / dueña del consultorio	`owner`	Indicadores, aprobación de campañas y descuentos por encima del tope del paquete.
Administración	`admin`	Personal, profesionales, cuentas de redes, guardia,

		documentos del conocimiento. No lee datos clínicos.
Recepción	`reception`	Pacientes, citas, planes, consentimientos, acceso del paciente, alertas.
Psicóloga / psiquiatra	`reviewer` (explícito)	Historia clínica, tests, archivos, seguimiento, revisión de respuestas retenidas.
Marketing	`marketing`	Campañas (crear, editar, aprobar dentro del tope, enviar, resultados).
Oficial de privacidad (DPO)	`privacy`	Exportación y borrado de datos del titular, auditoría, registro de casos de privacidad.
Paciente	llave `pk_`	Sus citas, turnos libres, reservas, chat, consentimientos, fidelidad.
Integración de software	llave de servicio	Sistema propio del consultorio; actúa como administración, sin acceso clínico.
Guardia	contacto de guardia	Recibe alertas de crisis por Telegram, WhatsApp y correo; reconoce y resuelve.
Agentes externos	A2A / MCP	Otros agentes de IA o editores que delegan tareas con protocolos estándar.

Cada persona tiene su propia llave (`sk_` personal o `pk_` de paciente) o inicia sesión con Google Identity Platform con MFA obligatoria (ADR 0018). El actor que aparece en la auditoría es siempre la persona dueña de la llave; un encabezado declarado por el cliente se ignora.

5. Vocabulario de estados y evidencia

5.1 Estado de un requisito

Estado	Significado
`I` Implementado	Existe el código y al menos una prueba automática que falla si se rompe; corre en CI.
`P` Parcial	Una parte está implementada y probada; el resto queda descrito.
`F` Futuro	Diseñado o planificado; no implementado.

5.2 Niveles de evidencia

Nivel	Descripción	Ejemplo en este producto
E1	Documento o decisión	ADR, política, plantilla legal
E2	Configuración versionada	Manifiestos Kubernetes, compose, Terraform
E3	Prueba unitaria o de integración	Módulos de `tests/` sobre SQLite y Postgres real
E4	Ensayo reproducible de extremo a extremo	CI: ensayo en kind y en servidor único con instalador real, demo completa, backup, reinicio y rollback
E5	Verificación independiente	Pentest externo, revisión legal (pendientes)

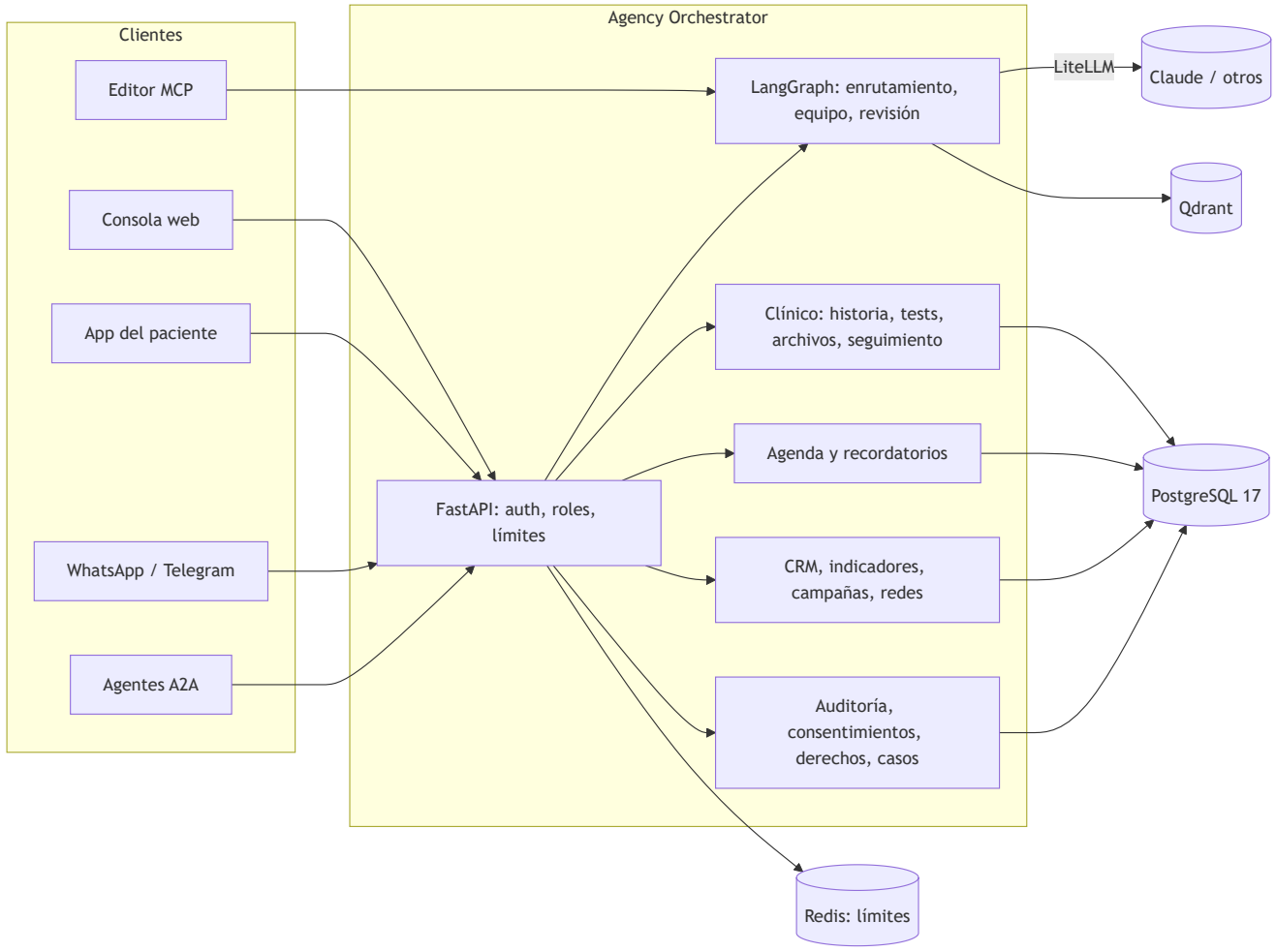
6. Flujo integral del producto

El recorrido de un paciente en el consultorio, de principio a fin, y lo que el sistema produce en cada paso.

#	Paso	Qué hace el sistema	Salida
1	Alta del consultorio	Crea el tenant con su paquete; registra profesionales con su propio paquete	Consultorio aislado
2	Personal y roles	Llaves personales o SSO con MFA	Personas identificadas
3	Conocimiento del consultorio	Sube políticas, precios, preguntas frecuentes; rechaza notas clínicas	Base de conocimiento por versión
4	Agenda	Horarios semanales por profesional	Turnos libres
5	Primer contacto	WhatsApp entrante: el asistente responde y ofrece 3 turnos reales	Reserva por número de opción
6	Alta del paciente	Recepción crea la ficha con id seudónimo	Paciente
7	Consentimientos	La app pregunta una vez, con texto honesto por paquete	Consentimiento por finalidad
8	Acceso del paciente	Llave `pk_` con caducidad	App del paciente
9	Recordatorio	Un día antes, sin contenido clínico	Recordatorio entregado
10	Sesión	Cambio de estado de la cita (confirmada, completada, no asistió)	Asistencia
11	Historia clínica	Nota de sesión o de psicoterapia, tipada por el paquete del autor	Entrada de solo agregar
12	Tests	PHQ-9, GAD-7 o test propio; puntaje, banda y alertas	Resultado versionado
13	Archivos	Consentimiento firmado fuera, subido con SHA-256	Archivo clínico
14	Seguimiento	Asistencia, riesgo de inasistencia con razones, tendencias de tests	Lista de pacientes que requieren atención
15	Pregunta clínica al asistente	Riesgo alto: se retiene; el profesional edita y aprueba	Respuesta revisada
16	Crisis	Texto fijo con ECU 911 y 171 op. 6; alerta y escalamiento	Alerta atendida
17	Indicadores	Segmentos y métricas calculadas con SQL; la IA solo narra	Resumen de dirección
18	Campaña	Copia revisada contra el paquete, aprobación, grupo control	Envío medible
19	Publicación en redes	Creatividad por código, reglas de la red, aprobación	Publicación

20	Resultados	Intención de tratar, Fisher, Wilson, Newcombe	Lift con intervalo
21	Derechos del titular	Exportación (sin notas de psicoterapia), borrado con retención clínica	Respuesta en plazo
22	Caso de privacidad	Pasos con fecha límite legal; alerta 24 h antes	Caso cerrado en plazo
23	Auditoría	Cadena de hashes verificable y anclas externas	Integridad demostrable
24	Retención	Purga de conversaciones inactivas; anonimización de marketing	Datos mínimos

7. Arquitectura



7.1 Tecnologías

Capa	Tecnología	Estado	Razón
API	FastAPI, Python 3.12/3.13	CONFIRMADA	Ecosistema de IA, tipado, OpenAPI
Orquestación IA	LangGraph 1.x	CONFIRMADA	Grafos con estado, interrupción para revisión humana, checkpoints
Modelos	LiteLLM (Claude por defecto)	CONFIRMADA	Independencia de proveedor, cadena de respaldo
Base de datos	PostgreSQL 17 con TLS	CONFIRMADA	Transacciones, bloqueos de fila, PITR en la nube
Migraciones	Alembic (0001–0018)	CONFIRMADA	Esquema versionado, verificado contra Postgres real
Vectores	Qdrant 1.19	CONFIRMADA	Índice por tenant; reconstruible desde Postgres
Límites compartidos	Redis 7.4	CONFIRMADA	Rate limit consistente entre réplicas
Consola	HTML + JS sin build, CSP estricta	CONFIRMADA	Sin dependencias de terceros en el navegador
Agente remoto	Java 21, Spring Boot 4, Spring AI 2 (A2A)	CONFIRMADA	Demostración políglota por protocolo
Identidad	Llaves por persona + OIDC (Google Identity Platform, MFA)	DECIDIDA (O7)	Mismo encargado que el hosting; sin subencargado nuevo
Producción MVP	Docker Compose + Cloudflare Tunnel en VM Oracle Always Free	DECIDIDA (ADR 0021)	US$0, sin puertos abiertos
Producción a escala	GKE Autopilot, Cloud SQL, Artifact Registry, Binary Authorization (Terraform)	LISTA, NO APLICADA	Requiere facturación
Observabilidad	OpenTelemetry, Prometheus, alertas con pruebas promtool	CONFIRMADA	SLOs y alertas por consumo de presupuesto de error

8. Requisitos funcionales

8.1 Consultorio, identidad y roles (ORG)

ID	Requisito	Estado	Verificación
ORG-01	Cada consultorio es un tenant aislado; ningún recurso de un tenant es legible con credenciales de otro, y la respuesta es idéntica a "no existe" (404).	I	test_tenant_isolation_matrix
ORG-02	Un consultorio registra N profesionales, cada uno con un paquete de profesión no abstracto (psicóloga, psiquiatra, odontología).	I	test_establishment
ORG-03	Llaves personales: sk_ con roles para personal, pk_ ligada a un paciente con caducidad; comparación en tiempo constante.	I	test_audit_regressions
ORG-04	Inicio de sesión OIDC con MFA obligatoria en producción; claims anidados (Google Identity Platform); aprovisionamiento al primer ingreso; "cerrar sesión en todas partes".	I	test_oidc
ORG-05	Los datos clínicos exigen el rol clínico explícito; administración y servicio reciben 403.	I	test_need_to_know
ORG-06	Revocación de una persona y de todas sus sesiones; auditada.	I	test_oidc
ORG-07	Inicio de sesión de la consola con PKCE; aprovisionamiento SCIM.	F	—

8.2 Gestión de pacientes (PAC)

ID	Requisito	Estado	Verificación
PAC-01	Crear paciente con id seudónimo opcional, listar (búsqueda por nombre, sin datos de contacto en el listado), abrir y editar. Id duplicado: 409.	I	test_crm, test_business_api
PAC-02	Cada apertura de ficha por una persona queda auditada.	I	test_crm
PAC-03	Un paciente restringido (tras borrado) rechaza ediciones, citas y planes nuevos (409).	I	test_crm
PAC-04	Citas con máquina de estados: programada → confirmada | completada | no asistió | cancelada; transiciones ilegales 409; estados finales definitivos.	I	test_crm, test_audit_regressions
PAC-05	Planes de tratamiento con etapas del paquete; mover a una etapa ajena: 422.	I	test_crm
PAC-06	Alertas tipo semáforo: citas sin confirmar, presupuestos sin respuesta, controles vencidos.	I	test_crm

PAC-07	Acceso del paciente: recepción emite una llave pk_ para la app.	I	test_business_api
PAC-08	Campos personalizados por paquete.	F	—

8.3 Perfil y portal del paciente (PAT)

ID	Requisito	Estado	Verificación
PAT-01	El paciente ve su perfil (/v1/me), sus citas, planes, consentimientos y fidelidad; nunca los de otro paciente.	I	test_tenant_isolation_matrix
PAT-02	Consentimientos preguntados una vez, con textos por paquete (salud mental: "nunca mencionan tu tratamiento"); sin respuesta = no.	I	test_profession_packs
PAT-03	Turnos libres reales y reserva propia; calendario firmado para su celular.	I	test_agenda
PAT-04	Chat del paciente con el asistente, con las mismas reglas de revisión.	I	test_business_api
PAT-05	App instalable (PWA / Play Store) y diario emocional.	F	pendiente abogada (I1, I3)

8.4 Agenda y recordatorios (AGD)

ID	Requisito	Estado	Verificación
AGD-01	Horarios semanales por profesional en la zona horaria del consultorio; turnos libres = horario − citas.	I	test_agenda
AGD-02	Sin doble reserva: la reserva bloquea la fila del profesional y rechaza cualquier solapamiento, también entre réplicas.	I	test_agenda, test_postgres_concurrency
AGD-03	Feeds iCalendar firmados con HMAC que muestran solo iniciales y horas.	I	test_agenda
AGD-04	Un recordatorio por cita, un día antes, sin contenido clínico: Telegram, plantilla de WhatsApp o app; respeta STOP; una sola vez con N réplicas.	I	test_reminders

8.5 Historia clínica y gestión documental (DOC)

ID	Requisito	Estado	Verificación

DOC-01	Entradas de solo agregar, tipadas por el paquete del autor (psicóloga: consentimiento en línea, certificado de asistencia, informe psicológico, resultado de escala; psiquiatra: receta ordinaria, hoja de receta especial, certificado médico, seguimiento de medicación; base común: consentimientos de terapia y de tutor, nota de sesión, nota de psicoterapia, derivación, informe de internamiento).	I	test_clinical_records, test_profession_packs
DOC-02	Corrección = nueva entrada que enmienda; nunca se sobrescribe.	I	test_clinical_records
DOC-03	Nota de psicoterapia visible solo para su autor; ni listada para otros.	I	test_clinical_records, test_surfaces
DOC-04	Archivos clínicos en la base de datos (hasta 10 MB), tipo comprobado por firma del contenido, SHA-256 al subir y al bajar, opción "solo yo".	I	test_clinical_files
DOC-05	Firma: el profesional firma fuera de la plataforma y sube el PDF; se conserva su SHA-256.	I	test_clinical_files
DOC-06	Hoja de receta especial validada contra ACESS-2022-0046 Arts. 6, 25 y 27 (campos, CIE-10, cantidad en letras y números, sin abreviaturas); el sistema nunca emite el formulario oficial.	I	test_prescriptions
DOC-07	Base de conocimiento del consultorio: subir, reemplazar, listar, borrar y buscar; texto canónico en Postgres; reindexado completo; rechazo de notas clínicas (403) antes de vectorizar.	I	test_knowledge, test_surfaces
DOC-08	Plantillas legales en español: aviso de privacidad, contrato de encargo, registro de actividades, evaluación de impacto.	P	docs/legal/es (revisión de abogada pendiente)
DOC-09	Extracción de texto de PDF/DOCX para la base de conocimiento.	F	—

8.6 Tests psicológicos y seguimiento (CLI)

ID	Requisito	Estado	Verificación
CLI-01	El profesional diseña cualquier test: ítems de opción, número o texto, ítems invertidos, suma o promedio, subescalas, bandas y alertas por ítem; privado o compartido.	I	test_instruments
CLI-02	Tests versionados: cada resultado guarda la versión con la que se puntuó.	I	test_instruments
CLI-03	Plantillas PHQ-9 y GAD-7 con las bandas de los artículos	I	test_scales,

	originales; ítem 9 del PHQ-9 > 0 genera alerta sea cual sea el total; se informa como banda, nunca como diagnóstico.		`test_instruments`
CLI-04	Seguimiento: asistencia, riesgo de inasistencia como regla con sus razones, tendencias por banda, participación en campañas solo con consentimiento de analítica, lista de pacientes con alerta.	I	`test_followup`
CLI-05	Textos oficiales en español de PHQ-9/GAD-7 para que el paciente los llene en la app.	F	P7

8.7 Asistente con IA y revisión humana (IA)

ID	Requisito	Estado	Verificación
IA-01	Enrutamiento en dos etapas a 260 especialistas (búsqueda + modelo pequeño), con respaldo; modo equipo con planificador en grafo.	I	`test_router, test_team`
IA-02	Respuestas basadas en el conocimiento del consultorio con citas verificadas; evidencia débil etiquetada.	I	`test_pathways, test_retrieval`
IA-03	Guardas de entrada: tamaño, inyección de instrucciones (ES/EN), datos personales redactados antes de llegar al modelo.	I	`test_guardrails`
IA-04	Riesgo alto (consejo clínico, división sensible, inyección marcada) pausa la respuesta; el profesional aprueba, edita o rechaza; la conversación queda bloqueada hasta decidir.	I	`test_governance, test_console_e2e`
IA-05	Cada respuesta lleva su procedencia: IA sin revisar, pendiente, editada y aprobada por un profesional.	I	`test_business_api`
IA-06	Memoria semántica solo con consentimiento, vocabulario cerrado de preferencias, sin datos clínicos.	I	`test_memory`
IA-07	Tope mensual de gasto en modelos por consultorio; al superarlo, textos fijos.	I	`test_spend`
IA-08	Interfaces MCP (editor) y A2A (agentes), con las mismas reglas de revisión.	I	`test_integrations`
IA-09	Evaluación de calidad con juez LLM calibrado, nocturna con modelos reales.	P	`test_judge (nocturna desactivada sin llaves)`

8.8 WhatsApp, crisis y guardia (WSP)

ID	Requisito	Estado	Verificación

WSP-01	Webhook firmado de Meta; mensajes deduplicados, clasificados al llegar; el texto nunca se guarda.	I	test_inbound
WSP-02	El asistente responde lo cotidiano con conocimiento del consultorio, nombre, próxima cita y 3 turnos; controles posteriores (medicación, dosis, diagnóstico, técnicas, enlaces, longitud) caen al texto fijo.	I	test_whatsapp_assistant
WSP-03	Reserva por código: "1", "2" o "3" reserva el turno ofrecido al paciente cuyo número coincide (única coincidencia).	I	test_whatsapp_assistant
WSP-04	Crisis y "quiero hablar con una persona": textos fijos revisados (ECU 911, 171 op. 6) y alerta al personal; nunca al modelo.	I	test_inbound, test_whatsapp_assistant
WSP-05	Guardia por niveles: aviso inmediato por Telegram, plantilla de WhatsApp y correo; escalamiento a los 5 min sin reconocimiento; sin datos del paciente en el aviso.	I	test_oncall
WSP-06	STOP registra baja seudónima (HMAC); respuesta humana dentro de la ventana de 24 h.	I	test_inbound, test_reidentification
WSP-07	Plantillas fuera de ventana, campañas por WhatsApp, respuestas a comentarios.	F	requiere cuenta Meta (A4)

8.9 Marketing: indicadores, campañas y redes (MKT)

ID	Requisito	Estado	Verificación
MKT-01	Segmentos por SQL (sin visitas, dormido, en riesgo, campeón, leal, nuevo, ocasional) con el intervalo de control del paquete.	I	test_crm
MKT-02	Resumen: pacientes, segmentos, top 20 % por valor, alertas, riesgo de inasistencia, embudo por etapa, pronóstico rotulado.	I	test_crm
MKT-03	Preguntas en lenguaje natural respondidas solo desde las métricas, citando la métrica.	I	test_crm
MKT-04	Campañas (control, reactivación, tratamiento pendiente, referidos, cumpleaños, educación); elegibilidad antes de dividir; población registrada; modo real o simulación fijado al crear.	I	test_campaigns
MKT-05	Copia revisada contra afirmaciones prohibidas del paquete ("la cura", "te cura"...) y detalles clínicos; solo {first_name}; STOP obligatorio.	I	test_campaigns, test_governance
MKT-06	Aprobación humana; descuento sobre el tope requiere a la dueña; envío una sola vez; versión aprobada fija.	I	test_campaigns

MKT-07	Grupo control por hash; resultados por intención de tratar: provisionales hasta cerrar la ventana de 30 días, luego Fisher, Wilson y Newcombe; "no concluyente" con menos de 30 por grupo; progreso diario.	I	test_campaigns, test_stats
MKT-08	Tope de contactos al mes por paciente; entrega primero en la app y Telegram a las 48 h; entregas inciertas nunca se reenvían.	I	test_campaigns
MKT-09	Creatividades por código (infografías JPEG, videos MP4 H.264) con pie de salud; la copia pasa las reglas antes de dibujar.	I	test_creatives
MKT-10	Cuentas de redes por consultorio o profesional; el token nunca se guarda (solo su referencia).	I	test_social
MKT-11	Publicación con verificación previa de reglas de cada red (Instagram, Facebook fotos, TikTok privado hasta auditoría), aprobación humana, una sola vez, "incierta" ante error de transporte, simulación sin credencial.	I	test_publishing
MKT-12	Publicidad pagada con aprobación previa del gasto, sin segmentar por condición de salud.	F	—
MKT-13	Insights tipo Vailati a partir de comentarios no clínicos con consentimiento.	F	—

8.10 Privacidad y derechos (PRV)

ID	Requisito	Estado	Verificación
PRV-01	Consentimientos por (titular, finalidad) con fuente; cada cambio auditado.	I	test_governance
PRV-02	Exportación del titular: consentimientos, CRM, historia (sin notas de psicoterapia, informando cuántas), tests, archivos, mensajes, auditoría.	I	test_clinical_records, test_instruments
PRV-03	Borrado: contacto y marketing se borran; la historia clínica se conserva restringida; marketing anonimizado con ids anon:.	I	test_crm, test_reidentification
PRV-04	Auditoría encadenada con hashes, verificable (/v1/audit/verify) y anclada en almacenamiento WORM.	I	test_governance
PRV-05	Registro de casos (acceso, rectificación, borrado, oposición: 15 días; brecha: clínica 2, SPDP + ARCOTEL 5, pacientes 3) con alerta 24 h antes.	I	test_privacy_cases
PRV-06	Clasificación de datos que decide qué puede ir a	I	test_classification

	cada destino (logs, prompts, búsqueda); detector de cédula; redacción de logs.		
PRV-07	Retención: purga de conversaciones inactivas y memoria vencida; trabajo programado con alertas.	I	test_limits_and_retention
PRV-08	Retención configurable de eventos de auditoría.	F	GOV-06

9. Requisitos no funcionales

ID	Categoría	Requisito	Estado
NFR-SEC	Seguridad	Producción se niega a arrancar sin llaves, con SQLite, sin TLS a Postgres, sin clave de seudónimos o con perfil no durable. CORS cerrado, HSTS, no-store, nosniff, frame-deny. CSP estricta en la consola.	I
NFR-TEN	Aislamiento	Toda tabla con clave primaria que empieza por `tenant` (prueba automática); Qdrant con índice `is_tenant`; matriz de ataque por operación.	I
NFR-REL	Confiabilidad	Circuit breaker al modelo, timeouts de sentencia y de bloqueo en Postgres, contrapresión (`MAX_INFLIGHT_MODEL_REQUESTS`), estados reclamados con UPDATE condicional.	I
NFR-PERF	Rendimiento	Medido: ~9 turnos de chat/s por proceso con 1,5 s por llamada al modelo (`docs/load-test.md`). Con proveedores reales: pendiente.	P
NFR-SCL	Escalabilidad	Servicio sin estado en proceso; HPA, PDB y topología en Kubernetes; límites en Redis; reservas y campañas seguras con varias réplicas (pruebas de concurrencia en Postgres).	I
NFR-OBS	Observabilidad	Trazas OTel por nodo del grafo y llamada al modelo; métricas; SLOs con alertas por consumo de presupuesto (probadas con promtool); runbooks por alerta.	I
NFR-DR	Recuperación	MVP: backup diario con SHA-256 y anclas (RPO 24 h). Escala: PITR de Cloud SQL (RPO 5 min, RTO 1 h). Simulacro de restauración automatizado.	I
NFR-REP	Reproducibilidad	`uv.lock` con `--frozen`; imágenes base por digest; catálogo como submódulo; colecciones nombradas por versión de catálogo y embedder.	I
NFR-MNT	Mantenibilidad	mypy estricto, ruff, reglas de arquitectura sobre el grafo de imports, ADR por decisión.	I
NFR-ACC	Accesibilidad	WCAG 2.1 AA verificado con axe en Chromium; navegación por teclado.	I

NFR-PORT	Portabilidad	Desarrollo en Windows; producción en Linux amd64 y arm64; Codespaces; Compose; Kubernetes.	I
NFR-COST	Costo	Libro de uso por solicitud, tope mensual por consultorio, perfil de producción a US$0.	I

10. Modelo de datos (principal)

Tabla	Campos clave	Clase de dato
crm_patients	(tenant, id), nombre visible, teléfono, correo, chat Telegram, nacimiento, canal preferido, restringido, borrado	Salud
crm_appointments	(tenant, id), paciente, inicio, duración, tipo, estado, precio, recordado	Salud
clinical_documents	(tenant, id), paciente, tipo, acceso, autor, profesional, paquete, cuerpo, sha256, enmienda	Psicoterapia
clinical_files	(tenant, id), paciente, nombre, tipo, sha256, acceso, autor	Psicoterapia
instruments / instrument_results	definición versionada / respuestas, puntaje, banda, alertas	Interno / Salud
professionals, professional_hours	profesional, paquete, llave de personal / horarios	Personal / Interno
consents	(tenant, titular, finalidad), otorgado, fuente	Personal
audit_events, audit_heads	secuencia, actor, acción, recurso, titular, detalles, hash previo	Auditoría
reviews	(tenant, hilo), estado, borrador, decisión	Salud
campaigns, campaign_recipients	tipo, segmento, plantilla, holdout, aprobaciones / brazo, estado	Interno / Personal
channel_accounts, publications	red, referencia de secreto / creatividad, sha256, estado	Credencial / Público
channel_alerts, on_call_contacts	alerta de crisis / guardia por nivel	Salud / Personal
privacy_cases, privacy_case_steps	tipo, titular, apertura / paso, base legal, vence, resultado	Salud
model_spend	(tenant, mes), costo, llamadas	Interno

Cada tabla tiene una clase de dato que decide a qué destinos puede ir (`classification.py`); una prueba falla si se crea una tabla sin clase.

11. Marco legal (Ecuador)

Obligación	Fuente	Control en el producto
Todo consultorio y la plataforma son tratamiento a gran escala	SPDP-2026-0005 Art. 14.1	Plantillas de EIPD y registro de actividades; DPO externo pendiente (L6)
DPO registrado (externo, empresa en Ecuador)	SPDP-2025-0028	Pendiente de la dueña
Servidor en el exterior con encargado no es transferencia	SPDP-2026-0004 Art. 23	Lista de subencargados; aviso al paciente (Art. 12.10)
Datos de salud anonimizados requieren aprobación SPDP	LOPDP Art. 31.3	Modelo entre consultorios apagado
Marketing y analítica requieren consentimiento; oposición en cualquier momento	LOPDP Arts. 8, 16.2	Consentimientos por finalidad, STOP
Derechos en 15 días	LOPDP Arts. 13–16	Registro de casos con alerta
Brecha: 2 / 5 / 3 días	LOPDP Arts. 43, 46	Registro de casos con alerta
Minimización	LOPDP Art. 10.e	Necesidad de saber; sin número del paciente en avisos
Seguridad del tratamiento	LOPDP Art. 37	TLS, cifrado en reposo del proveedor, auditoría
Receta especial (psicotrópicos)	ACESS-2022-0046	Validador de la hoja; nunca emite el formulario

> Este SRS es una especificación técnica, no asesoría legal. Los plazos se cuentan en días calendario, que nunca son más tarde que los días hábiles (*término*); la abogada debe confirmar *término* frente a *plazo* (L7).

12. Seguridad y privacidad

- **Identidad:** llaves por persona con roles; OIDC con MFA; acceso de emergencia documentado.

- **Autorización:** rol + tenant + necesidad de saber para datos clínicos.
- **Datos en tránsito:** HTTPS (Cloudflare o Gateway de GKE), TLS a Postgres en producción.
- **Secretos:** nunca en código ni base de datos; referencias por nombre; gitleaks sobre todo el historial.
- **Cadena de suministro:** acciones fijadas por SHA, Trivy antes de publicar, SBOM y procedencia, firma cosign sin llaves, verificación antes de desplegar, Binary Authorization en GKE.
- **Contenedores:** no root, sistema de archivos de solo lectura, sin capacidades, `no-new-privileges`.
- **Red:** Kubernetes con deny-all por defecto; servidor único sin puertos de entrada.
- **IA:** guardas de entrada, delimitación de datos no confiables, citas verificadas, revisión humana, tope de gasto.
- **Documentos:** modelo de amenazas y alcance de pentest en `docs/security/`.

13. CI/CD y reproducibilidad

```
push a main → lint y tipos → pruebas (py3.12 y 3.13, Postgres real) → evaluación de enruta
```

Etapa	Qué demuestra	Bloquea
Lint & types	ruff (incluye reglas de seguridad), formato, mypy estricto	Sí
Tests	900+ pruebas, cobertura ≥ 80 % (hoy 95 %), en Postgres no UTC	Sí
Routing eval	top-1 ≥ 0,50 y recall@8 ≥ 0,80 sin modelo	Sí
Java A2A	34 pruebas JUnit + contrato en vivo	Sí
Security scan	Trivy (dependencias, secretos, IaC), gitleaks	Sí
Manifests	Kustomize renderizado y validado; reglas de alertas probadas	Sí
Images	Escaneo CRÍTICO antes de publicar; firma por digest	Sí
Ensayo kind	Despliegue real y rollback de una versión rota	Sí, antes de producción
Ensayo servidor único	Instalador real, todos los flujos de la demo, backup, reinicio con datos, versiones sin firma rechazadas	Sí, antes de producción

Rama protegida: sin borrado, sin force push, PR con los 8 checks obligatorios; producción exige la aprobación de la revisora del entorno `production`.

14. Despliegue y operación

	MVP (hoy)	Escala (cuando haga falta)
Dónde	Una VM Oracle Always Free (ARM) con Docker Compose	GKE Autopilot + Cloud SQL (Terraform)
Entrada	Cloudflare Tunnel (sin puertos abiertos)	Gateway HTTPS con certificado administrado
Costo	US$0	~US$175–450/mes por entorno
Despliegue	`deploy.sh`: firma → migración → salud → humo → rollback automático	`rollout.sh` con el mismo contrato
RPO / RTO	24 h / horas	5 min / 1 h
Cuándo pasar	Segunda clínica, compromiso de disponibilidad, más de ~5 turnos/s sostenidos o un RPO de 24 h inaceptable.	

Operación: SLOs (`docs/slo.md`), alertas a Telegram (+ correo) para la guardia de la plataforma, runbooks por alerta, backup nocturno, simulacro de restauración.

15. Estrategia de pruebas

Capa	Qué prueba	Módulos
Unitarias	Puntajes, estadística, reglas de copia, validador de receta	`test_scales, test_stats, test_prescriptions`
Integración	API + base de datos + grafo	`test_business_api, test_service`
Postgres real	Migraciones con datos, concurrencia de dos réplicas, zona horaria	`test_migrations, test_postgres_concurrency`
Seguridad	Aislamiento por operación, necesidad de saber, reidentificación, regresiones de auditorías	`test_tenant_isolation_matrix, test_need_to_know, test_reidentification, test_audit_regressions`
Resiliencia	Caída del modelo, del vector store y de la base	`test_resilience, test_remote_chaos`
E2E navegador	Revisión, espacio clínico, agenda, WCAG AA	`test_console_e2e`
IA	Enrutamiento, citas, juez calibrado	`test_router, test_pathways, test_judge`
Despliegue	Manifiestos, scripts de rollback ejecutados con docker falso	`test_deploy_config, test_single_node, test_rollout_script`
Arquitectura	Reglas del grafo de imports	`test_architecture`

16. Registro de decisiones

ID	Estado	Decisión
ADR 0001	CONFIRMADA	Enrutamiento en dos etapas con respaldo
ADR 0002	CONFIRMADA	Índice inmutable versionado por catálogo y embedder
ADR 0003/0007	CONFIRMADA	Núcleo Python, agentes políglotas por A2A
ADR 0004	CONFIRMADA	Modo equipo con planificador en grafo
ADR 0005	CONFIRMADA	Checkpoints en Postgres
ADR 0006	CONFIRMADA	Juez LLM calibrado para evaluar respuestas
ADR 0008	CONFIRMADA	Evidencia graduada y registro de ruta
ADR 0009	CONFIRMADA	Revisión humana y gobierno

ADR 0010	CONFIRMADA	Memoria semántica con consentimiento
ADR 0011–0013	CONFIRMADA	CRM, métricas SQL, campañas con grupo control y medición
ADR 0014	CONFIRMADA	Paquetes de profesión (Ecuador)
ADR 0015	CONFIRMADA	Canales sociales con reglas leídas de fuentes oficiales
ADR 0016	CONFIRMADA	HTTPS, HSTS, CORS cerrado
ADR 0017	CONFIRMADA	Guardia con escalamiento
ADR 0018	DECIDIDA (O7)	SSO con MFA; Google Identity Platform
ADR 0019	DECIDIDA	Espacio clínico: tests propios, archivos, seguimiento
ADR 0020	DECIDIDA	Agenda, recordatorios y asistente de WhatsApp
ADR 0021	DECIDIDA	Producción MVP en un servidor; Kubernetes para escalar
O1–O4, O6	DECIDIDA	Alertas, RPO/RTO, staging separado, Artifact Registry, Binary Authorization
O5	CONFIRMADA	Rama protegida y entornos con revisora (hecho por la dueña)
P9b	DECIDIDA	Administración no lee datos clínicos
L1–L8	PENDIENTE	Consulta legal, DPO, plantillas, contratos con subencargados
A4, A9	PENDIENTE	Cuentas Meta / WhatsApp; dominio propio
O8	PENDIENTE	Pentest independiente

17. Registro de riesgos

ID	Severidad	Riesgo	Mitigación
R-01	Crítico	Fuga de datos entre consultorios	Clave por tenant, matriz de ataque por operación, pruebas de aislamiento en vectores
R-02	Crítico	Crisis no atendida	Textos fijos, guardia multicanal, escalamiento a 5 min, alerta de página a los 15 min
R-03	Alto	Consejo clínico de la IA	Revisión humana, controles posteriores deterministas, textos fijos
R-04	Alto	Uso con pacientes reales sin cumplimiento legal	Pasos legales como compuerta del lanzamiento (LAUNCH.md §5)

R-05	Alto	Caída del servidor único	Backup nocturno con copia fuera del servidor; camino a GKE ensayado
R-06	Alto	Imagen maliciosa en producción	Firma verificada antes de desplegar; Binary Authorization en GKE
R-07	Medio	Publicidad engañosa en salud	Afirmaciones prohibidas por paquete, pie de salud, aprobación humana
R-08	Medio	Costo de modelos	Tope mensual, contrapresión, embeddings locales
R-09	Medio	Pruebas intermitentes en CI	Se corrige la causa (p. ej. llave de tarjeta de revisión sin marca de tiempo), no se reintenta a ciegas
R-10	Bajo	Dependencia de un proveedor	LiteLLM, Compose y Kubernetes portables, Terraform

18. Hoja de ruta

Fase	Entregables	Estado
0–1 Fundación y núcleo	Orquestación, RAG, revisión, auditoría, CRM, campañas	Hecho
2 Salud mental	Paquetes psicóloga/psiquiatra, historia clínica, tests, receta	Hecho
3 Marketing y canales	Creatividades, redes, WhatsApp, crisis, guardia	Hecho
4 Agenda y seguimiento	Agenda, recordatorios, asistente, seguimiento	Hecho
5 Producción	CI/CD firmado, SSO, perfiles de despliegue, privacidad	Hecho
6 Lanzamiento piloto	VM Oracle, pasos legales, DPO, pentest, una clínica	En curso (dueña)
7 App del paciente	PWA, diario emocional, tests en la app	Futuro
8 Odontología y medicina	Migrar paquete dental; médicos generales y especialidades	Futuro
9 ERP	Facturación, pagos, inventario	Futuro

19. Estado exacto al cerrar este SRS

Elemento	Estado
Código	En GitHub, rama `main` protegida, último commit `5020f70`
CI	Verde en todas las etapas; ensayos kind y servidor único verdes

Ensayo servidor único	Verde desde `5020f70` (instalador real, demo completa, backup, reinicio con datos, versiones sin firma rechazadas). Antes, CI encontró y se corrigieron dos causas: TLS de Postgres y Redis sin cambio de usuario.
Demo	Funcionó de extremo a extremo con datos sintéticos por túnel de Cloudflare desde la PC de la dueña
Servidor de producción	Pendiente: crear la VM Oracle y ejecutar el instalador (`docs/DEPLOY-SINGLE-NODE.md`)
Pacientes reales	No permitido hasta L1–L8 (abogada, DPO, contratos)
Dominio	No existe (A9); se usa dirección rápida de Cloudflare

20. Criterios de aceptación

ID	Criterio	Estado
`AC-01`	Otro consultorio no obtiene datos, vectores, archivos ni auditoría de un consultorio.	`I`
`AC-02`	Administración no puede leer la historia clínica.	`I`
`AC-03`	Una nota de psicoterapia solo la ve su autor y no sale en la exportación.	`I`
`AC-04`	Un mensaje de crisis nunca llega al modelo y genera alerta.	`I`
`AC-05`	Una respuesta clínica riesgosa no se muestra sin revisión humana.	`I`
`AC-06`	No hay dos citas superpuestas para un profesional, ni con dos réplicas.	`I`
`AC-07`	Una campaña no se envía sin consentimiento, aprobación ni opción STOP.	`I`
`AC-08`	Un resultado de campaña no declara efecto antes de cerrar su ventana.	`I`
`AC-09`	La auditoría detecta cualquier alteración de su cadena.	`I`
`AC-10`	Un plazo legal de privacidad avisa 24 h antes de vencer.	`I`
`AC-11`	CI bloquea cualquier versión con pruebas fallidas; producción solo recibe imágenes firmadas.	`I`
`AC-12`	Una versión rota se revierte sola sin dejar de atender.	`I`
`AC-13`	El sistema se instala de cero en un servidor limpio con un comando.	`I`

21. Glosario

Término	Definición
Tenant	Consultorio: espacio aislado de un cliente.
Paquete de profesión	Reglas declarativas de una profesión: documentos, afirmaciones prohibidas, consentimientos, crisis, prescripción.
Revisión humana	Pausa de una respuesta de riesgo alto hasta que un profesional decide.
Grupo control (holdout)	Pacientes elegibles que no reciben la campaña para medir su efecto real.
Intención de tratar	Comparar a todos los asignados, recibieran o no el mensaje.
Necesidad de saber	Solo accede quien lo necesita para su función (LOPDP Art. 10.e).
Cadena de auditoría	Eventos encadenados por hash; alterar uno rompe la verificación.
A2A / MCP	Protocolos abiertos entre agentes y entre editores y herramientas.
RPO / RTO	Cuántos datos se pueden perder / cuánto se tarda en volver.
Digest	Huella SHA-256 de una imagen; no cambia, a diferencia de una etiqueta.
Binary Authorization	Control de GKE que solo admite imágenes atestadas.

22. Matriz de trazabilidad

Objetivo	Requisitos	Módulo	Prueba principal
SaaS seguro	ORG, NFR-TEN	auth, oidc, security	`test_tenant_isolation_matrix, test_need_to_know`
Paciente bien atendido	PAC, PAT, AGD	crm, portal, agenda, reminders	`test_crm, test_agenda, test_reminders`
Historia clínica íntegra	DOC, CLI	clinical_records, clinical_files, instruments, followup	`test_clinical_records, test_instruments`
IA controlada	IA, WSP	graph, risk, whatsapp_assistant, inbound	`test_governance, test_whatsapp_assistant`
Marketing ético y medible	MKT	campaigns, stats, publishing, creatives	`test_campaigns, test_stats, test_publishing`
Privacidad demostrable	PRV	governance, subject_rights, privacy_cases	`test_privacy_cases, test_reidentification`

Entrega confiable	NFR-REP, NFR-DR	deploy/, workflows	`test_single_node`, `test_deploy_config`, `test_backup_restore`
